

Equipo de Respuesta a Incidentes (CSIRT)

Objetivo general

El presente documento tiene como objetivo definir el actuar de este equipo para proteger los activos críticos para la organización, previamente definidos en el documento de gestión de riesgos.

Objetivo particular

El equipo tiene como propósito los siguiente:

- Proteger la información sensible de la organización, salvaguardando su confidencialidad, integridad y disponibilidad.
- Minimizar el impacto a la operatividad y reputación de la organización.
- Garantizar que la organización opere a pesar de que haya un incidente.

Alcance

El CSIRT responderá a los incidentes presentados dentro de las 3 áreas de la organización:

- Desarrollo de Software
- Atención a clientes
- Administración

Ayudando así a proteger la infraestructura critica para la operación.

Definiciones

CSIRT: Equipo especializado encargado de detectar, analizar, responder y recuperar a la organización de incidentes de seguridad informática.

Incidente de seguridad: Evento que compromete la confidencialidad, integridad o disponibilidad de la información o de los sistemas.

Evento de seguridad: Cualquier suceso observable en un sistema.

Alerta: Notificación generada por herramientas de seguridad que indican una posible amenaza.

Vulnerabilidad: Debilidad en un sistema, proceso o control que puede ser explotada por una amenaza.

Amenaza: Cualquier evento o actor con capacidad de causar daño a un sistema o información.

Riesgo: Probabilidad de que una amenaza explote una vulnerabilidad y cause un impacto.

Impacto: Consecuencia negativa generada por un incidente en la organización.

Contención: Acciones destinadas a limitar la propagación de un incidente.

Erradicación: Proceso de eliminación completa de la causa del incidente.

Recuperación: Restauración de sistemas y servicios a su estado normal.

Malware: Software malicioso diseñado para dañar o comprometer sistemas.

SIEM: Sistema que permite monitorear y analizar eventos de seguridad en tiempo real.

Clasificación de incidentes

Bajo: No afecta a la operación

Medio: Afecta limitadamente a un sistema o empleado.

Alto: Interrumpe parcialmente la operación de algunos sistemas.

Crítico: Interrumpe totalmente la operación (fuga de datos o ataques informáticos).

Roles y responsabilidades

Líder del CSIRT

- Coordinar todas las actividades del equipo de respuesta a incidentes.
- Autorizar la activación del BCP y coordinar el DRP.
- Tomar decisiones estratégicas durante los incidentes.
- Informar a la dirección general sobre el estado del incidente.

Analista de seguridad

- Monitorear eventos y detectar posibles incidentes
- Analizar alertas y determinar el nivel de riesgo.
- Ejecutar acciones para contener y erradicar la causa del incidente.
- Documentar cada incidente y sus resultados.

Coordinador de comunicación

- Informar a las áreas internas sobre el incidente.
- Gestionar la comunicación con clientes en caso necesario.
- Compartir comunicados oficiales.

Área de TI

- Apoyar en la implementación de medidas técnicas.
- Recuperar los sistemas.
- Administrar herramientas de seguridad.

Todos los empleados

- Reportar cualquier evento sospechoso.
- Cumplir con las políticas de seguridad.

Relación con BCP y DRP

El líder del CSIRT será responsable de activar el BCP cuando un incidente afecte la continuidad de la empresa. En caso de daño a infraestructura, se coordinará con el DRP para la recuperación técnica.

Comunicación

Se deben usar canales de comunicación oficiales (Principales/Alternos). Se evitará compartir información sensible sin autorización.

Proceso de respuesta a incidentes

Fases

1. Detección y reporte

Se detectan eventos anómalos mediante herramientas (como SIEM, alertas, monitoreo) o por reportes de empleados. Todo evento sospechoso debe ser reportado inmediatamente al CSIRT para realizar un registro inicial del incidente.

2. Análisis

Se clasifica el incidente (bajo, medio, alto, crítico) para posteriormente identificar los sistemas afectados y evaluar impacto a la empresa.

3. Contención

Se aíslan los sistemas comprometidos y se bloquean los accesos no autorizados para impedir la propagación del malware.

4. Erradicación

Se debe de eliminar correctamente el malware o el acceso malicioso, además de identificar y corregir las vulnerabilidades explotadas. Una vez realizado lo anterior se debe de validar que el sistema ya no esté comprometido.

5. Recuperación

El área de TI junto al CSIRT restauran los sistemas y se valida la integridad de la información para reintegrar el sistema a la red corporativa.

6. Lecciones aprendidas

Se debe de documentar completamente el incidente, identificar la causa raíz para implementar mejoras en los controles de seguridad y actualizar políticas y procedimientos

Gestión de evidencias

Para cumplir correctamente con la gestión de evidencias se debe de:

- Recolectar y guardar los logs y registros del incidente íntegramente, no se debe de realizar modificación alguna ya que servirá para realizar un análisis y/o uso legal.

Capacitación y Concientización

Objetivo

Fortalecer la cultura de la seguridad de la información y garantizar una correcta respuesta ante incidentes. Por ello se establecen programas de capacitación tanto para el personal general como para el CSIRT

Capacitación para los empleados

Todo el personal de la organización deberá recibir capacitación anual sobre temas de seguridad de la información, para prevenir incidentes. En el caso particular de los nuevos empleados, su primera capacitación será al ser contratados.

Temas de la capacitación:

- Identificar correos de phishing
- Uso seguro de contraseñas y el doble factor de autenticación.
- Manejo adecuado de la información sensible.
- Procedimiento para el reporte de incidentes.

Capacitación para el CSIRT

El equipo de respuesta a incidentes deberá recibir capacitación especializada cada 6 meses para garantizar una respuesta efectiva ante incidentes de seguridad.

Temas de la capacitación:

- Análisis y gestión de incidentes.
- Uso de herramientas de monitoreo, como SIEM o IDS/IPS.
- Análisis forense digital.
- Gestión de vulnerabilidades.
- Respuesta ante ataques informáticos, como malware, ransomware, DDoS.

Simulacros

Se deben de realizar simulacros de incidentes de seguridad anualmente con el propósito de evaluar la respuesta del CSIRT y de los empleados ante escenarios de riesgo. Esta evaluación nos permitirá validar que el proceso de respuesta a incidentes, BCP y DRP son efectivos en situaciones reales.

Simulacros por realizar:

- Simulacros de escritorio: Se analizarán escenarios hipotéticos en donde el CSIRT y los empleados describirán el paso a paso de como actuarían ante el incidente.
- Simulacros técnicos: El CSIRT realizara acciones reales en entornos controlados para practicar la recuperación de sistemas.
- Simulacros integrales: Estos simulacros se llevará a cabo contemplando todas las áreas de NovaTech para coordinar el actuar general y fomentar la mejora continua.